

APIs REST Seguras com Node.js

Programação e Sistemas de Informação · Guia de estudo

STUDY	FLOW
Compreender	Praticar

Objetivos de aprendizagem

- Distinguir autenticação de autorização.
- Validar input antes da lógica de negócio.
- Aplicar respostas HTTP e erros consistentes.

Como usar este guia

Lê cada secção, reproduz o exemplo sem consultar a solução e termina com os exercícios. Usa a checklist para decidir o que precisas de rever.

Contrato antes da implementação

Uma API robusta começa por definir recursos, operações, formatos de pedido e resposta, regras de autorização e falhas previsíveis. O controller recebe o pedido, valida o contrato e delega a lógica num service coeso.

Validação e controlo de acesso

Todo o input externo é não confiável. Validar tipos, limites e formatos reduz estados inválidos. Depois da autenticação, cada operação deve confirmar se o utilizador pode atuar sobre o recurso concreto.

Erros seguros

Erros públicos devem usar códigos estáveis e mensagens úteis sem expor stack traces, queries, segredos ou detalhes internos. Logs técnicos ficam no servidor e devem evitar dados pessoais desnecessários.

Exemplo orientado

Passo	Aplicação
Pedido	POST /api/projects com title e dueDate.
Validação	Rejeitar título vazio e data inválida antes de escrever.
Autorização	Confirmar que o projeto pertence à turma do utilizador.
Resultado	201 para criação; 400, 403 ou 404 para falhas previstas.

Exercícios de consolidação

1. Definir o contrato de PATCH /api/projects/:id.
2. Listar três casos limite para paginação.
3. Explicar porque um ID válido não prova autorização.

Checklist final

- Input validado
- Autorização por recurso
- Erros sem dados sensíveis
- Operações idempotentes quando necessário
- Testes de sucesso e falha

Regista uma dúvida concreta e escolhe um exercício semelhante para a próxima sessão. A aprendizagem melhora quando o erro é usado como informação.